CC5052NI Risk, Crisis & Security Management

50% Individual Coursework

on

{Zero Trust Architecture}

Semester 3

2024-25 Autumn

Student Name: Pradip Joshi

London Met ID: 23047485

College ID: np01nt4a230162

Assignment Due Date: Tuesday, December 3, 2024

Assignment Submission Date: Tuesday, December 3, 2024

I confirm that I understand my coursework needs to be submitted online via MST Classroom under the relevant module page before the deadline in order for my assignment to be accepted and marked. I am fully aware that late submissions will be treated as non-submission and a mark of zero will be awarded.

Abstract

The rapid development of the digital world has made Zero Trust (ZT) a critical security priority for all the organizations worldwide. This report explores the concept of Zero Trust in detail, importance of Zero Trust in improving cybersecurity, especially considering the increasing shift towards hybrid work environments post-pandemic. It explains the core principles of Zero Trust including verifying explicitly, enforcing least privilege access, and assuming breach, which shifts the mindset from reactive to proactive security measures. By adopting these principles, Zero Trust significantly improves an organization's ability to defend against a wide range of cyber threats and vulnerabilities, providing a more robust framework for securing sensitive data and critical systems.

This report also discusses the Zero Trust Maturity model that provides a structured approach to implement Zero Trust across five key pillars: Identity, Devices, Networks, Applications and workloads, and Data. By using this model, organizations can gradually optimize their Zero Trust security posture. This report also examines the benefits of implementing Zero Trust in the business environment. Such as improving compliance, reducing attack surfaces and enhancing employee productivity by enabling secure access from anywhere.

This report also evaluates a case where a financial services company named Capital One that offers a range of credit products to consumers and businesses suffered a cyber-attack. This report gives insights on what happened and the loss that the company had to bear along with the weaknesses and Negligence that enabled the attacker to get access to data is also discussed. Finally, this report also discusses how the implementation of Zero Trust (ZT) could have prevented or minimized the impact of the attack. Overall, the report shows the significance of Zero Trust in enhancing defense of organization against evolving cyber threats.

It is suggested to have a basic level of understanding on IT security to get a complete understanding on what the report is trying to present.

List of contents

List of Abbreviations 5
1. Introduction 6
1.1. Background 6
1.2. Aims and Objectives 7
2. Literature review 8
2.1. What is Zero Trust? 8
2.2. Why Zero Trust? 8
2.3. Zero Trust Framework 8
2.4. Zero Trust Maturity Model 9
3. Methodology and Analysis 12
3.1. What happened? 12
3.2. How did it happen? 12
3.3. How Zero Trust would have prevented this incident? 13
4. Conclusion 15
References 16

List of Figures

Figure 1: Survey on criticality of Zero Trust 6
Figure 2: Survey on reason to shift towards Zero Trust 7
Figure 3: Zero Trust Framework 8
Figure 4: Zero Trust Maturity Model Pillar 9

List of Abbreviations

Terms	Abbreviations
ZTA	Zero Trust Architecture
ZT	Zero Trust
ZTMM	Zero Trust Maturity Model
IoT	Internet of Things
OIDC	OpenID Connect
SAML	Security Assertion Markup Language
RBAC	Role-Based Access Controls
DoD CS RA	Department of Defense Cybersecurity Reference Architecture
PII	Personally Identifiable Information
DLP	Data Loss Prevention
DRM	Data Rights Management
WAF	Web Application Firewall
SSRF	Server-Side Request Forgery
AWS	Amazon Web Services
CLI	Command Line Interface
SDK	Software Development Kit
API	Application Programming Interface
APT	Advanced Persistent Threats
NSA	National Security Agency
CISA	

1. Introduction

1.1. Background

Insider threats, ransomware, data breaches and phishing were some of the emerging cybersecurity dangers that were not addressed by traditional perimeter-based security strategies. Hackers took advantage of weak points like insider as the attack surface expanded due to the growth of remote work and cloud computing. The serious security breaches, user mistrust and operational disruptions caused by these issues highlighted the importance of a strong security architecture like ZT. It became essential to guarantee ongoing validation and reduce vulnerabilities, addressing the limitation of traditional perimeter-based security strategies.

Organizations now focus their security policies on business objectives due to the increasing number of cloud apps, mobile devices, remote workers, and IOT connected equipment. Adopting ZT means adopting procedures and technology that promote business agility and improve security.

The Zero Trust strategy has become a top security priority across industries, with **53%** of organizations considering it essential. It is considered a high priority in the **U.S. (56%)** and **Germany (53%)** where almost every security professional **(96%)** sees it as critical strategy for their organization's success. The ZT approach is being adopted by security experts to improve end-user experience, streamline security procedures for staff, and strengthen the security framework.

Figure 1: Survey on criticality of Zero Trust

Top Motivators	
Improve overall security posture	47%
Improve end user experience and productivity	44%
Transform the way security teams work together	38%
Simplify security stack	35%
Reduce security costs	35%

Figure 2: Survey on reason to shift towards Zero Trust

Therefore, this report focuses on exploring various aspects of Zero Trust and its need in the present context.

1.2. Aims and Objectives

The main of this report is to provide a comprehensive and detailed understanding of the ZT framework, its significance in modern cybersecurity, and its effectiveness in addressing emerging threats and vulnerabilities and the objectives are:

1. To gain comprehensive understanding of the zero-trust.
2. To evaluate the need of ZT.
3. To explore the framework of ZT.
4. To know about the Zero Trust Maturity Model
5. To explore the Capital One data breach case.
6. To analyze how zero-trust could have protected that organization or minimized the impact.

2. Literature review

2.1. What is Zero Trust?

ZT is a security method that focuses on moving away from a location-centric approach to more data-centric approach to achieve enhanced security controls among users, systems, data and assets that may vary over time.

In ZT, it is assumed that any users or devices that reside within or outside the enterprise network cannot be trusted. This is in contrast to the traditional security approach, which often require authentication for users outside the network and trust individuals and devices inside the network.

2.2. Why Zero Trust?

Based on context and identification, ZT substitutes explicit trust for implicit trust. While restricting non-users to authorized resources exclusively, it safely links entities to resources, enabling users to access applications. ZT follows the core principles of "just in time" and "just enough" by enforcing a dynamic and consistent approach to protect resources and visualize which user is accessing particular apps. Through the alignment of authentication with risk, this method minimizes user friction while promoting a uniform security posture and access policies across users, devices and locations.

2.3. Zero Trust Framework

ZT is a security approach that works on the three core principles. They are: Verify explicitly, Use Least privilege access and Assume breach.

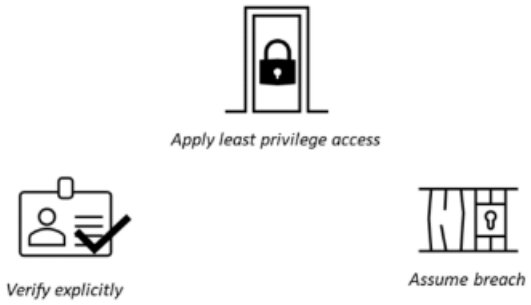

Figure 3: Zero Trust Framework

Verify explicitly: It includes always authenticating and authorizing on all the available data points (Microsoft, 2024). Standardized authentication protocols such as OIDC, SAML, Token-based authentication, multi-factor authentication are some techniques that can be used for authentication.

Least privilege: It includes granting users only the access they require just like an army commander being provided with the information only they need to know. This allows us to reduce the exposure of the sensitive parts of the network (Cloudflare, 2024) . Least privilege can be implemented by using the techniques like role-based access controls that gives permissions based on job roles and responsibilities.

Assume breach: It means minimizing the Containment Zone and segment access. End-to-end encryption can be used, and proper analysis should be done to get visibility, drive threat detection, and improve defenses.

2.4. Zero Trust Maturity Model

ZTMM outlines a progressive approach to implement Zero Trust principles to five pillars where little improvements can be made over time towards optimization. The pillars are Identity, Devices, Networks, Applications and Workloads, and Data. Each pillar gives general information on cross-cutting abilities. They are: Analytics and Visibility, Automation and Governance and Orchestration.

Figure 4: Zero Trust Maturity Model Pillar

The pillars of Zero Trust Maturity Model are described below:

Identity

Users and entities should have access to the authorized resources only when necessary and for the appropriate purpose. Identity, credential and access management solutions should be combined across the whole organization to enforce robust authentication, customized context-based authorization, and to evaluate identity risk for agency's users and entities. Integration of the identity stores and management systems should be done across the enterprise to increase awareness of enterprise identities and their duties and authorities.

Devices

The device pillar suggests that all the devices that are connected or trying to connect to the organization's resources must be located, listed, authenticated and assessed. It instructs to setup the environment where the devices are permitted or denied accessing the resources based on dynamic risk calculation.

Networks

ZT facilitates shift from conventional perimeter-focused security strategies and allows to control internal and external traffic flows, isolate hosts, enforce encryption, segment activities and improve network visibility across the enterprise. It strengthens defense-in-depth and complements conventional network security by enabling the implementation of security controls closer to applications, data and other resources.

Applications and Workloads

Application security refers to protecting application by preventing exceptions to the application or underlining information system's security policies. By combining features from the user, device, network and environment pillars, the application and workload pillar aims in securing access at the application layer to stop data exfiltration, illegal access, and interference with vital operations or services. Applications are further secured with a smaller attack surface by adhering to the DoD CS RA concept, which demands that least privilege should be implemented by setting systems to give just necessary authorization.

Data

The attacker targets the data in many forms (Customer records, user credentials, proprietary information, employee (PII), intellectual property, personal emails etc.). The ZT is built as a data-centric security model that leverages each connected pillar to guarantee the availability, confidentiality and integrity of the data, regardless of the location.

DLP techniques, encryption, tagging and labelling, and the application of DRM technologies are some of the techniques used by data pillar to secure and enforce access to data both in transit and at rest.

3. Methodology and Analysis

This section focuses on comparing the issues that allowed the Capital One attacker to gain access with the corresponding ZT solutions that could have prevented or mitigated the attack.

3.1. What happened?

In 2019, Capital One revealed that it suffered from a cyber incident which targeted the financial services firm resulting the extraction of the details of about 106 million clients from US and Canada. The corporation revealed that the data leaked included details of 100 million customer from US and Canda. In the US, 80,000 linked bank account numbers and 140,000 social security numbers were impacted. Approximately 1,000,000 social insurance numbers owned by Capital One credit card were affected in Canada. The attacker was able to get contact details, credit scores limit, balances, and payment history along with names and date of birth.

According to court filings in Seattle, a 33-year-old suspect named Paige Thompson was detained and charged with one count of computer fraud and abuse.

3.2. How did it happen?

The report prepared by CloudSploit, the FBI, and Mr. Brian Krebs helped to identify the actions performed during cyberattack. The information on the process of exploitation is discussed below:

1. The FBI and Capital One found various entryways using anonymizing tools like TOR Network and VPN service IPredator. The attacker's IP address was hidden by using both services.

2. The attacker was able to deceive the server to run commands remotely that provided the attacker entry to the private server, by exploiting the SSRF vulnerability.

3. The misconfiguration of the WAF enabled the trespasser to deceive the firewall into sending commands to the metadata service which is a default back-end resource on the AWS platform.

4. the attacker obtained the AccessKeyID and SecretAccessKey credentials from a role identified in the FBI indictment as "*****-WAF-Role" by using the URL http://169.254.169.254/iam/security-credentials, taking advantage of both SSRF and WAF misconfiguration. These temporary credentials enabled the attacker to run commands within the AWS environment using API, CLI, or SDK.

5. Using the credentials, the attacker repeatedly ran the “ls” command, which provided a list of all AWS S3 Buckets associated with the compromised Capital One account.

6. The “sync” command of AWS was used by the attacker to copy approximately 30 GB of credit application data of Capital One from the buckets of the local machine of the attacker. With that command, the attacker was able to access over 700 buckets.

3.3. How Zero Trust would have prevented this incident?

The solution for every exploit taken place in Capital One by using ZT are described below:

1. Anonymizing services and IP blocking

ZT would have enforced strict identity verification and continuous authentication of every entity. It would have ensured continuous validation of the identity of entity, flagging suspicious activity like frequent change in geographic location or device fingerprints. Attempts to access from any anonymous entity would have been blocked, making it harder for attackers to hide behind VPNs or anonymizers.

2. Exploitation of SSRF vulnerability

ZT would have implemented strict control policies to limit access to resources and servers by any requests. In SSRF attacks, the attacker can make the server send the request to an unauthorized location. ZT would have solved this by isolating services and restricting communication unless explicitly authorized, preventing unauthorized access.

3. WAF misconfiguration.

The misconfiguration of the WAF allowed the attacker to fool the firewall into forwarding commands to a default back-end resource on the AWS platform, referred to as the metadata service. ZT would have ensured that no commands or requests are forwarded to internal services without explicit permissions, preventing unauthorized access to credentials.

4. Accessing AWS temporary credentials via SSRF and WAF misconfiguration.

ZT would have enforced strict access controls on the metadata service and credentials, limiting access only to authorized roles. The principle of least privilege would also ensure that temporary credentials like AWS AccessKeyID and SecretAccessKEY are granted only to entities that require

them and with the minimum necessary permissions. Even with an SSRF vulnerability or WAF misconfiguration, the attacker would be unable to access sensitive AWS credentials without explicit authorization.

5. Command execution in AWS using stolen credentials.

ZT would have monitored all actions performed by each entity, including those executed through the AWS CLI, SDK, or API. All commands, especially ones involving critical actions like accessing S3 buckets or synchronizing data, would need to be continuously authenticated. Even with the stolen credentials, ZT would limit the scope of their use by enforcing granular access controls.

6. Data exfiltration via AWS Sync command.

ZT would have applied DLP policies and ensured that any data access or exfiltration is tightly controlled, even within AWS environments. Even if the attacker has obtained valid credentials, ZT would have enforced strict controls on data movement, blocking mass data exfiltration (such as 30 GB data) by analyzing behavior patterns and limiting what an attacker can do with the credentials.

4. Conclusion

The threat landscape is evolving rapidly making the traditional perimeter-based security insufficient, which makes the adoption of ZT necessary. As organizations adopt cloud computing, remote work and IOT devices, the need for a more dynamic, data-centric security approach becomes more important.

ZT offers a robust framework that focuses on continuous verification, least privilege access, and assuming breach that ensures that all the entities are continuously authenticated and monitored, regardless of their location inside or outside the network.

This report discusses the ZTMM, which provides a structured, progressive approach for implementing ZT principles. It divides the approach into five pillars: Identity, Devices, Networks, Applications and workloads, and Data that offers a roadmap for continuous improvement and optimization of organization's security.

The analysis of the case of Capital One data breach case shows the need for implementation of ZT principles. It shows how ZT would have minimized the attacker's ability to exploit vulnerabilities like SSRF or misconfigured WAF by implementing strict identity verification, segmentation of access, and the enforcement of robust access controls. Additionally, the integration of DLP and continuous monitoring could have reduced the risk of massive data exfiltration.

Overall, this report highlights the importance of adopting ZTA as a critical component of any organization's cybersecurity strategy. By aligning security policies with business goals, ZT enhances security posture and supports business agility and resilience. As organizations continue to face sophisticated cyber threats, ZT works a critical strategy for safeguarding sensitive data and ensuring long-term cybersecurity success.

References

(NSA) National Security Agency , 2024. *Advancing Zero Trust Maturity Throughout the Application and Workload Pillar.* [Online] Available at: https://media.defense.gov/2024/May/22/2003470825/-1/-1/0/CSI-APPLICATION-AND-WORKLOAD-PILLAR.PDF
[Accessed 26 November 2024].

(NSA) National Security Agency, 2024. *Advancing Zero Trust Maturity Throughout the Data.* [Online]
Available at: https://media.defense.gov/2024/Apr/09/2003434442/-1/-1/0/CSI_DATA_PILLAR_ZT.PDF
[Accessed 26 November 2024].

BBC, 2019. *Capital One data breach: Arrest after details of 106m people stolen.* [Online] Available at: https://www.bbc.com/news/world-us-canada-49159859
[Accessed 22 December 2024].

CISA (Cybersecurity and Infrastructure Security Agency), 2023. *Zero Trust Maturity Model ,* Washington, D.C.: CISA (Cybersecurity and Infrastructure Security Agency).

Cloudflare, 2024. *Zero Trust security | What is a Zero Trust network?.* [Online] Available at: https://www.cloudflare.com/learning/security/glossary/what-is-zero-trust/
[Accessed 11 november 2024].

CyberArk Blog Team, 2023. *What Is Zero Trust and Why Is it So Important?.* [Online] Available at: https://www.cyberark.com/resources/blog/what-is-zero-trust-and-why-is-it-so-important
[Accessed 26 November 2024].

frontegg, 2024. *Complete Guide to Authentication in 2024.* [Online] Available at: https://frontegg.com/blog/authentication
[Accessed 27 November 2024].

Gartner, 2024. *Implement Zero-Trust Architecture to Adapt to a Shifting Threat Landscape.* [Online]

Available at: https://www.gartner.com/en/cybersecurity/topics/zero-trust-architecture [Accessed 26 November 2024].

Microsoft, 2021. *Zero Trust Adoption Report,* Redmond, Washington: Microsoft.

microsoft, 2024. *What is Zero Trust?.* [Online] Available at: https://learn.microsoft.com/en-us/security/zero-trust/zero-trust-overview [Accessed 27 november 2024].

Microsoft, 2024. *What is Zero Trust?.* [Online] Available at: https://learn.microsoft.com/en-us/security/zero-trust/zero-trust-overview [Accessed 27 november 2024].

Nelson Novaes Neto, S. M. A. M. G. d. P. N. M. B., 2020. *A Case Study of the Capital One Data Breach ,* Cambridge, MA: MIT Management SLOAN SCHOOL.

paloalto, 2024. *What Is the Principle of Least Privilege?.* [Online] Available at: https://www.paloaltonetworks.com/cyberpedia/what-is-the-principle-of-least-privilege
[Accessed 27 November 2024].

Rotlevi, S., 2023. *How to Implement Zero Trust: A Simplified Guide.* [Online] Available at: https://www.wiz.io/academy/how-to-implement-zero-trust [Accessed 26 November 2024].

SANS Cyber Defense, 2023. *What is Zero Trust Architecture?.* [Online] Available at: https://www.sans.org/blog/what-is-zero-trust-architecture/ [Accessed 26 November 2024].

Weise, E. F. a. K., 2019. *Capital One Data Breach Compromises Data of Over 100 Million.* [Online]
Available at: https://www.nytimes.com/2019/07/29/business/capital-one-data-breach-hacked.html
[Accessed 22 December 2024].

William Yeoh, M. L. M. S. F. J., 2023. Zero trust cybersecurity: Critical success factors and A maturity. *Computers & Security ,* 133(1), p. 13.